

> Hardening Email Sender Authentication:
A Lab-Based Evaluation of SPF/DKIM/DMARC
Misconfigurations

Guilherme Ferreira João Oliveira Ayrton da Cruz Ana Lúcia Ferreira

Faculdade de Engenharia - Universidade do Porto

April 6, 2026

> Table of Contents

1 Introduction

2 Lab Setup

3 Misconfigurations Explored

4 Attack Execution

5 Results & Observations

6 Hardening Recommendations

7 Next Steps

8 References

> Introduction

loading module...

> Why Email Authentication Matters

- Email remains a primary vector for phishing attacks.
- SPF, DKIM, and DMARC were designed to mitigate spoofing.
- Misconfigurations still allow successful impersonation.

> Lab Setup

loading module...

> Docker-Compose Architecture

```
version: "3"
services:
  dns-server:      # BIND
  victim-mail:     # Postfix/Dovecot
  attacker-sender: # Espoofers + custom scripts
  webmail:         # User interface for the email service
```

- DNS server exposes misconfigured SPF, DKIM, and DMARC records.
- Victim mail server runs on 10.9.0.6 with docker-mailserver.
- Attacker container mounts Espoofers and custom attack scripts.

> Misconfigurations Explored

loading module...

> SPF / DKIM / DMARC Misconfigurations

- SPF: v=spf1 a mx ~all versus -all.
- DKIM: weak selector, missing key rotation, or absent selector.
- DMARC: p=none versus p=reject with reporting.

Observation

- Weak or inconsistent policy combinations can still let spoofed mail reach the inbox.

> Attack Execution

loading module...

> Running Espoofers from the Attacker Container

```
docker exec attacker-sender-10.9.0.7 \  
  /home/seed/espoofer/espoofer \  
  -u attacker@example.com \  
  -t alice@victim.test \  
  -f "Subject: Test" \  
  -m "Hello, this is a spoofed mail."
```

Observation

- The attacker sends a crafted spoofed message toward the victim domain.
- Misconfigured validation logic determines whether delivery succeeds.

> Results & Observations

loading module...

> Email Authentication Outcomes

Test	SPF	DKIM	DMARC
Baseline (correct config)	Pass	Pass	Pass
Soft-fail SPF	Pass	Pass	Pass
DKIM selector missing	Pass	Fail	Pass
DMARC p=none	Pass	Pass	Pass

- DKIM misconfiguration is the most relevant vector for successful spoofing.
- DMARC with p=none gives visibility but no enforcement.

> Hardening Recommendations

loading module...

> DNS-Level Fixes

- Use `-all` in SPF to enforce a hard fail.
- Publish a valid DKIM selector and rotate keys regularly.
- Publish DMARC with `p=reject` or `p=quarantine`.

> MTA-Level Fixes

- Enforce SPF checks on inbound connections.
- Reject mail that fails DKIM verification.
- Reject mail that violates DMARC policy.

> Next Steps

loading module...

> Future Work

- Automate misconfiguration detection in the lab.
- Expand the attack set with additional spoofing scenarios.
- Publish a reproducible Docker image for the environment.

> References

loading module...

> References I



O. Foundation, “A02:2025 – security misconfiguration,” https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/, 2025, accessed: 2026-03-16.



——, “A07:2025 – authentication failures,” https://owasp.org/Top10/2025/A07_2025-Authentication_Failures/, 2025, accessed: 2026-03-16.



J. Chen, V. Paxson, and J. Jiang, “Composition kills: A case study of email sender authentication,” *Proceedings of the 29th USENIX Security Symposium*, pp. 2183–2199, 2020.



J. Chen. (2024) Espoofer: An email spoofing testing tool. Accessed: 2026-03-16. [Online]. Available: <https://github.com/chenjj/espoofer>



Infraforge. (2026) Spf, dkim, dmarc: Common setup mistakes. Accessed: 2026-03-16. [Online]. Available: <https://www.infraforge.ai/blog/spf-dkim-dmarc-common-setup-mistakes>



DMARCLY. (2024) How to implement dmarc/dkim/spf to stop email spoofing/phishing. Accessed: 2026-03-16. [Online]. Available: <https://dmarcly.com/blog/how-to-implement-dmarc-dkim-spf-to-stop-email-spoofing-phishing-the-definitive-guide>